

INFORMATION SECURITY RISK ASSESSMENT

NIST Cybersecurity Framework (CSF) Version 2.0 Aligned
Community Education Program — Data Privacy and Compliance Focus

Prepared for
Compass Community Health Education
A Nonprofit Community Health Education Organization

Prepared by: Zaakirah Taylor
Assessment Period: June 1 – July 1, 2026
Report Date: July 18, 2026
Classification: Confidential – Internal Use Only

Framework: NIST CSF 2.0 | Regulatory Scope: HIPAA Privacy & Security Rules | Functions Assessed: Govern • Identify • Protect • Detect • Respond • Recover

NOTE: This assessment was conducted on a fictional community health education organization as a demonstration of NIST CSF 2.0 risk assessment methodology. The findings reflect realistic risk patterns applicable to organizations of this type and are intended to demonstrate the analytical approach and deliverable format a formal assessment of a real organization would produce.

1. Executive Summary

This report presents the findings of an information security risk assessment conducted for Compass Community Health Education (“Compass” or “the Organization”), a fictional nonprofit community health education organization. The assessment was performed using the NIST Cybersecurity Framework Version 2.0 (CSF 2.0) and evaluated against requirements under the HIPAA Privacy and Security Rules, given the Organization’s status as a HIPAA-covered entity that collects and processes protected health information (PHI) and personally identifiable information (PII) from program participants.

The assessment identified 11 risks across all six NIST CSF 2.0 Functions. Of these, 2 were rated Critical, 3 High, 4 Medium, and 2 Low. The most urgent findings concern the absence of a formal incident response plan and uncontrolled access to participant data by outreach staff using personal devices — both presenting direct HIPAA exposure and operational risk.

1.1 Summary of Risk Ratings

Risk Rating	Count	% of Total	Examples
Critical	2	18%	No incident response plan; uncontrolled PHI access on personal devices
High	3	27%	MFA gaps; no formal data retention policy; stale volunteer access
Medium	4	36%	Security awareness gaps; unsecured file sharing; SOP gaps
Low	2	18%	Physical sign-in sheet security; email retention

2. Assessment Scope and Methodology

2.1 Organizational Profile

Attribute	Detail
Organization Name	Compass Community Health Education
Organization Type	Nonprofit 501(c)(3) — Community health education
Size	7 staff, 15–20 active volunteers; 3 program sites (Philadelphia area)
Programs	Community health education (sexual health, STI prevention, reproductive health literacy); school-based outreach; DHS partner programs; community events
Regulatory Status	HIPAA Covered Entity — subject to Privacy Rule, Security Rule, and Breach Notification Rule. Participant health information (STI testing referrals, health intake forms) constitutes PHI.
Systems in Scope	Google Workspace (Gmail, Docs, Sheets, Forms, Drive); Zoom (virtual program delivery); online participant intake forms (Google Forms); shared program drive; funder/affiliate reporting portal; volunteer scheduling platform
Third Parties	STI testing laboratory partner; school district partners (data sharing agreements); DHS referral partner; cloud storage (Google); Zoom
Data Types Handled	PHI (health intake forms, STI testing referrals, participant health history); PII (name, contact info, age, demographic data); program participation records; funder reporting data

2.2 NIST CSF 2.0 Functions

This assessment is organized around all six NIST CSF 2.0 Functions:

- GOVERN (GV) — Cybersecurity risk management strategy, policy, and organizational accountability
- IDENTIFY (ID) — Understanding assets, data, and cybersecurity risks to people and systems
- PROTECT (PR) — Safeguards to manage risk and ensure delivery of services
- DETECT (DE) — Activities to identify cybersecurity events in a timely manner
- RESPOND (RS) — Actions to take when a cybersecurity incident is detected
- RECOVER (RC) — Maintaining resilience and restoring capabilities after an incident

2.3 Risk Rating Methodology

Each identified risk was scored using a 5×5 Likelihood × Impact matrix. The product of both scores determines the overall Risk Rating.

Score	Likelihood	Score	Impact	Rating Thresholds
1	Rare (unlikely in 12 months)	1	Negligible (no disruption, no exposure)	15–25 = Critical
2	Unlikely (no history)	2	Minor (limited disruption, no breach)	8–14 = High
3	Possible (plausible, industry precedent)	3	Moderate (disruption, limited PHI exposure)	4–7 = Medium
4	Likely (has occurred at org)	4	Major (significant	1–3 = Low

Score	Likelihood	Score	Impact	Rating Thresholds
			disruption, reportable breach)	
5	Almost Certain (expected / active threats)	5	Severe (large-scale breach, regulatory action)	

3. Risk Register

The following register details all 11 identified risks, organized by NIST CSF 2.0 Function.

3.1 GOVERN (GV)

GV-01: No Formal Incident Response Plan

Risk Description	Compass has no documented incident response plan. Staff have no defined process for identifying, reporting, or escalating a potential data breach or security incident. In the event of a PHI breach, the HIPAA Breach Notification Rule requires notification to affected individuals within 60 days — a timeline that cannot be met without prior planning.
Affected Assets / Data	All participant PHI and PII; funder data; program records
Existing Controls	No written IRP exists. Staff informally report concerns to the Executive Director. No defined escalation path, breach notification timeline, or designated Privacy Officer role.
HIPAA Reference	<i>HIPAA Security Rule §164.308(a)(6) — Security Incident Procedures; Breach Notification Rule §45 CFR Part 164 Subpart D</i>
Likelihood / Impact	4 / 5 (Score: 20)
Overall Risk Rating	Critical

GV-02: Information Security Policies Not Documented or Reviewed

Risk Description	Compass does not have formal, written information security policies covering acceptable use of technology, data handling, password requirements, or remote work security. Staff operate from informal norms without documented expectations, increasing inconsistency and compliance exposure.
Affected Assets / Data	Organization-wide; all staff and volunteer technology use
Existing Controls	No written policies on file. Some informal guidance provided during onboarding but not documented or consistently enforced.
HIPAA Reference	<i>HIPAA Security Rule §164.308(a)(1) — Security Management Process; §164.316 — Policies and Procedures</i>
Likelihood / Impact	3 / 3 (Score: 9)
Overall Risk Rating	Medium

3.2 IDENTIFY (ID)

ID-01: No Inventory of Participant Data Locations

Risk Description	Compass does not maintain a centralized inventory of where participant PHI and PII is stored, processed, or transmitted. Data exists across Google Forms, Google Sheets, email attachments, and paper intake forms across three sites — with no formal data flow map or asset register.
Affected Assets / Data	Google Workspace (Forms, Sheets, Drive); paper intake forms; email; staff personal devices (in some cases)
Existing Controls	No data inventory or data flow map on file. Staff informally know where data lives but no formal documentation exists.

HIPAA Reference	<i>HIPAA Security Rule §164.308(a)(1)(ii)(A) — Risk Analysis (requires identifying where ePHI is stored and transmitted)</i>
Likelihood / Impact	3 / 4 (Score: 12)
Overall Risk Rating	High

ID-02: Risk Assessment Not Conducted on Recurring Basis

Risk Description	Compass has not previously conducted a formal, structured risk assessment aligned to a recognized framework. The HIPAA Security Rule requires covered entities to conduct periodic risk analyses. The absence of recurring risk assessment leaves the organization without a systematic view of its security posture.
Affected Assets / Data	Organization-wide compliance posture
Existing Controls	No prior formal risk assessment on file. This report represents the first structured assessment using NIST CSF 2.0.
HIPAA Reference	<i>HIPAA Security Rule §164.308(a)(1)(ii)(A) — Risk Analysis</i>
Likelihood / Impact	3 / 3 (Score: 9)
Overall Risk Rating	Medium

3.3 PROTECT (PR)

PR-01: Participant PHI Accessed on Personal/Unmanaged Devices

Risk Description	Outreach staff and volunteers routinely access participant intake forms, contact lists, and scheduling data on personal smartphones and laptops that are not managed by Compass IT. These devices may lack encryption, automatic screen lock, or malware protection, creating significant PHI exposure risk if a device is lost, stolen, or compromised.
Affected Assets / Data	Participant PHI and PII in Google Workspace; intake forms; contact and scheduling data
Existing Controls	No device management policy or MDM solution in place. Staff are not prohibited from accessing organizational data on personal devices. No encryption verification occurs.
HIPAA Reference	<i>HIPAA Security Rule §164.312(a)(2)(iv) — Encryption and Decryption; §164.310(d) — Device and Media Controls</i>
Likelihood / Impact	4 / 5 (Score: 20)
Overall Risk Rating	Critical

PR-02: MFA Not Enabled on Google Workspace Accounts

Risk Description	Multi-factor authentication is not enforced on any Google Workspace account used by Compass staff or volunteers. Google Workspace contains participant forms, contact data, program records, and email — all accessible with a password alone. Credential-based attacks (phishing, password spray) represent a known and active threat against nonprofits.
Affected Assets / Data	Google Workspace (Gmail, Drive, Forms, Sheets) containing PHI and PII
Existing Controls	MFA available in Google Workspace Admin Console but not enabled or enforced. Staff use passwords only.
HIPAA Reference	<i>HIPAA Security Rule §164.312(d) — Person or Entity Authentication</i>
Likelihood / Impact	4 / 4 (Score: 16)
Overall Risk Rating	High

PR-03: Volunteer Access Not Deprovisioned Upon Offboarding

Risk Description	Volunteers who complete programs or leave Compass are not systematically removed from Google Workspace, shared drives, or scheduling platforms. Access reviews are not conducted. Former volunteers may retain access to participant contact lists and program materials indefinitely.
Affected Assets / Data	Google Drive shared folders; volunteer scheduling platform; participant contact data
Existing Controls	No formal offboarding checklist or access revocation process. Access changes are made on request but no recurring access review occurs.
HIPAA Reference	<i>HIPAA Security Rule §164.308(a)(3) — Workforce Security; §164.312(a)(1) — Access Control</i>
Likelihood / Impact	3 / 4 (Score: 12)
Overall Risk Rating	High

PR-04: No Formal Data Retention or Disposal Policy

Risk Description	Compass does not have a documented policy governing how long participant data is retained, when it should be deleted, and how physical records (paper intake forms) should be disposed of. Old participant intake forms and contact lists may be retained indefinitely across shared drives and paper files.
Affected Assets / Data	Google Drive (historical intake data); paper intake forms at all three sites
Existing Controls	No retention policy. Data is kept unless actively deleted. Paper forms stored in filing cabinets without defined retention schedule or secure disposal process.
HIPAA Reference	<i>HIPAA Privacy Rule §164.530(j) — Documentation; HIPAA Security Rule §164.310(d)(2)(i) — Disposal</i>
Likelihood / Impact	3 / 3 (Score: 9)
Overall Risk Rating	Medium

PR-05: Participant Data Shared via Unsecured Email Attachments

Risk Description	Staff occasionally share participant contact lists and program data with partner organizations (school districts, DHS) via unencrypted email attachments. Depending on the data transmitted, this may constitute unsecured transmission of PHI outside Compass' controlled environment.
Affected Assets / Data	Participant PII and PHI transmitted via email; partner organization interfaces
Existing Controls	No secure file transfer protocol in place. Data sharing occurs via Gmail attachments. Some partners have data sharing agreements but no technical controls govern how data is transmitted.
HIPAA Reference	<i>HIPAA Security Rule §164.312(e)(1) — Transmission Security</i>
Likelihood / Impact	3 / 3 (Score: 9)
Overall Risk Rating	Medium

3.4 DETECT (DE)

DE-01: No Process for Detecting Unauthorized Access to Participant Data

Risk Description	Compass has no monitoring or alerting capability to detect if participant data in Google Drive or Forms is accessed by unauthorized individuals (including former volunteers), shared externally, or downloaded in bulk. Unauthorized access would only be discovered reactively.
Affected Assets / Data	Google Workspace (Drive, Forms, Gmail); participant intake data
Existing Controls	Google Workspace Admin Console provides access logs but no one monitors them. No alerts configured for unusual file access, external sharing, or bulk downloads.
HIPAA Reference	<i>HIPAA Security Rule §164.312(b) — Audit Controls</i>
Likelihood / Impact	3 / 3 (Score: 9)
Overall Risk Rating	Medium

3.5 RESPOND (RS)

RS-01: No Staff Training on Security Incident Recognition or Reporting

Risk Description	Staff and volunteers have not received training on how to recognize or report a potential security incident — including phishing emails, lost devices, or accidental data sharing. The first line of detection in a small organization is its people; without training, incidents are likely to go unreported until significant harm has occurred.
Affected Assets / Data	All staff and volunteer endpoints; email (primary phishing vector); participant data
Existing Controls	No security awareness training program exists. Staff received general onboarding but no specific guidance on recognizing phishing, reporting lost devices, or handling data incidents.
HIPAA Reference	<i>HIPAA Security Rule §164.308(a)(5) — Security Awareness and Training</i>
Likelihood / Impact	4 / 4 (Score: 16)
Overall Risk Rating	High

3.6 RECOVER (RC)

RC-01: No Documented Data Backup or Recovery Process

Risk Description	Compass relies on Google Workspace cloud storage for program data but has no documented backup or data recovery plan. Google provides some version history, but staff are unaware of recovery procedures, retention limits, or what would happen to data if the account were compromised or terminated.
Affected Assets / Data	Google Drive (all program data, participant records, operational files)
Existing Controls	Google Workspace provides cloud storage with version history. No separate backup solution, no documented recovery procedure, no staff awareness of recovery capabilities.
HIPAA Reference	<i>HIPAA Security Rule §164.308(a)(7) — Contingency Plan</i>
Likelihood / Impact	2 / 2 (Score: 4)
Overall Risk Rating	Low

RC-02: Physical Intake Forms Not Secured During Transport Between Sites

Risk Description	Paper participant intake forms collected at community events and school sites are transported between Compass' three locations in staff vehicles without a defined chain of custody or secure transport procedure. Loss of a bag or vehicle break-in could expose PHI.
Affected Assets / Data	Paper PHI (participant intake forms, health history forms) in transit between program sites
Existing Controls	No written transport policy. Staff are aware to keep forms with them but no formal procedure or secure container requirement exists.
HIPAA Reference	<i>HIPAA Security Rule §164.310(c) — Workstation Security; §164.310(d) — Device and Media Controls</i>
Likelihood / Impact	2 / 2 (Score: 4)
Overall Risk Rating	Low

4. Remediation Plan

The following roadmap prioritizes corrective actions by risk rating. Critical risks should be addressed within 0–30 days. All recommended actions assume limited budget and small staff capacity typical of a nonprofit community health organization.

4.1 Remediation Roadmap

ID	Recommended Action	Owner	Timeline	Rating
GV-01	Develop and test a written Incident Response Plan including breach notification roles, timelines, and escalation paths aligned to HIPAA Breach Notification Rule	Executive Director / Privacy Officer designee	0–30 days	Critical
PR-01	Establish a device security policy requiring password protection and screen lock on any device used to access participant data; evaluate MDM solution (free tiers available for nonprofits)	Operations Lead	0–30 days	Critical
PR-02	Enable and enforce MFA on all Google Workspace accounts via Admin Console (no cost, built-in feature)	Operations Lead / Admin	0–14 days	High
RS-01	Deliver security awareness training to all staff and volunteers: phishing recognition, lost device reporting, and data handling requirements (Google's Phishing Quiz is a free starting resource)	Program Coordinator / Manager	30–60 days	High
PR-03	Implement a formal volunteer offboarding checklist including Google Workspace access revocation; conduct a one-time access review to remove stale accounts	Program Coordinator	30–60 days	High
ID-01	Create a data inventory documenting where participant PHI and PII is stored, processed, and transmitted across all three sites and external partners	Program Coordinator	30–90 days	High
PR-05	Establish a secure file transfer procedure for sharing participant data with partners; evaluate Google Drive shared folder access as alternative to email attachments	Program Coordinator / Operations	60–90 days	Medium
GV-02	Draft core information security policies: Acceptable Use, Data Handling, Password Requirements, Remote Work/Device Security	Executive Director	60–90 days	Medium
PR-04	Develop a data retention and disposal policy; implement a scheduled annual review and secure shredding process for paper intake forms	Operations Lead	90–120 days	Medium
ID-02	Establish an annual risk assessment cycle to monitor changes in the threat landscape and organizational risk	Program Coordinator / Leadership	90–120 days	Medium

ID	Recommended Action	Owner	Timeline	Rating
	posture			
DE-01	Configure Google Workspace Admin Console alerts for bulk file downloads, external sharing, and login anomalies (built-in, no additional cost)	Operations Lead / Admin	60–90 days	Medium
RC-01	Document the data recovery procedure for Google Workspace; communicate to all staff	Operations Lead	30–60 days	Low
RC-02	Define a written procedure for secure transport of paper PHI between sites; provide a secure transport bag or container for each site	Operations Lead	60–90 days	Low

4.2 Prioritization Rationale

Critical risks (GV-01 and PR-01) were prioritized first because they represent the highest combined likelihood and impact scores and carry direct HIPAA regulatory exposure. GV-01 (no incident response plan) is particularly urgent because without it, Compass cannot meet the 60-day breach notification requirement regardless of what other controls are in place. PR-01 (unmanaged personal devices) was prioritized alongside it because it represents the most probable current vector for PHI exposure — staff and volunteers actively use personal devices today, with no controls in place.

PR-02 (MFA) was elevated to the top of the High tier because it is the highest-impact control Compass can implement at zero cost, with the fastest deployment timeline — a single Admin Console configuration change. The Medium risks were sequenced based on complexity and dependency: policies (GV-02) were placed before procedures (PR-04) because procedures should derive from written policies, not the reverse.

5. Conclusion and Next Steps

This assessment identified 11 risks across all six NIST CSF 2.0 Functions at Compass Community Health Education. While the Organization has established some informal compliance practices through its HIPAA-regulated programming, the absence of formal documentation, access controls, and incident response planning creates meaningful exposure for participant data and organizational continuity.

The most urgent priorities — developing an Incident Response Plan and establishing basic device security requirements — can be completed with existing staff and at minimal cost within 30 days. Several High-priority items (MFA enforcement, volunteer offboarding, awareness training) similarly require only internal effort and built-in platform features already available in Google Workspace.

Addressing the full remediation roadmap over 90–120 days would meaningfully close the identified gaps and position Compass for stronger audit readiness, reduced HIPAA exposure, and a more sustainable security posture as the organization grows.

5.1 Recommended Immediate Next Steps

1. Assign a Privacy Officer designee (if not already in place) as the accountable owner for HIPAA compliance and this remediation effort.
2. Enable MFA on all Google Workspace accounts this week — this is the single highest-impact, zero-cost action available.
3. Draft or adapt a basic Incident Response Plan, ensuring staff know what to do and who to call if participant data is lost, stolen, or improperly disclosed.
4. Conduct a one-time access review: audit who currently has access to shared Google Drive folders and program data, and remove any inactive or former volunteer accounts.
5. Schedule a 60-minute security awareness session with all current staff and active volunteers covering phishing, device security, and data handling expectations.
6. Establish a recurring annual risk assessment cycle to maintain visibility into the organization's evolving security posture.

Project Note: This assessment was conducted on a fictional community health education organization as a demonstration of NIST CSF 2.0 risk assessment methodology. The organization, personnel, and findings described are fictitious and were constructed to reflect realistic risk patterns in a HIPAA-covered, resource-constrained nonprofit setting. All HIPAA rule citations are accurate and verifiable against the official CFR text. This deliverable represents the type of assessment that would be produced for a real organizational engagement.